Atelier d'autodéfense numérique

I. MÉTÉO / GESTES DE FACILITATION

- Lever un doigt, deux, etc
- Point technique
- d'accord / pas d'accord
- chapeau pour demander le silence

N'hésitez pas à demander une pause si vous en ressentez le besoin

II. INTRO

II.1. Contenu de la formation : ce qu'on fait et ce qu'on fait pas, à qui ça s'adresse

Le but de la formation c'est pas d'être exhaustif sur tous les sujets (au contraire, on va essayer de rester plutôt en surface) Le but de la formation est de rendre les participant·es autonomes sur les questions de la vie privée numérique, cela passe par une compréhension des technologies et leur fonctionnement La formation est structurée pour comprendre comment fonctionne le capitalisme de surveillance, quels sont les risques, et comment y remédier (le mieux possible) + mise à disposition une grosse liste de ressources pour creuser les sujets en autonomie.

- De cette façon, les participant·es peuvent passer du temps les sujets qui les intéressent ou qu'iels trouvent les plus cruciaux
- Ça permet à la formation de toucher un plus large public et de répondre aux attentes et/ou besoins de chacun. La formation se veut comme une porte d'entrée vers le domaine de la sécurité informatique. On va volontairement faire des approximations, et ce, dans un but **pédagogique**.
- /!\ On va peu/pas aborder les sujets relatifs au militantisme dans cette formation, il y a une formation dédiée pour ça (sécurité militante)
- les questions de clarification seront prioritaire sur les questions d'approfondissement, qui seront traitées à la fin de la formation ou autour d'un verre
- si vos intervations sont rrop technniues, on se reéserve le droit de vous couper, on pourra en parler à la fin de la formation, ou autour d'un verre.

Point d'info (pas utile de le dire sauf questions)

- faire un nuage de mots si vous le sentez
- donnez les mots qui vous viennent à l'esprit quand on parle de secu num.

II.2. Autodéfense numérique : pourquoi c'est important

L'ensemble des techniques et technologies pour faire respecter vos libertés individuelles (parce que d'autres ne sont pas capable de les faire respecter pour vous, ou ont des intérêts à ce qu'elles soient bafouées)

- l'autodéfense numérique c'est comprendre comment sont utilisées les technologies pour bafouer nos libertés individuelles, et comprendre comment s'en protéger (comprendre quel est le problème, pour pouvoir mettre en place des solutions) (dans autodéfense, il y a auto => comprendre le sujet, être autonome, être assez formé pour pouvoir faire des choix pertinents)

- l'autodéfense numérique c'est reprendre le contrôle sur votre vie numérique, faire respecter votre consentement (ou surtout son absence) à la collecte et au traitement de vos données personnelles
- La sécurité numérique, ce n'est pas que pour vous, c'est pour protéger vos proches, vos camarades et le mouvement ! La sécurité est comme une chaîne : elle est aussi solide que son maillon le plus faible

III. QUELQUES ÉLÉMENTS THÉORIQUES

III.1. Mise au point sur le vocabulaire

Suggestions / À faire

Faire des étiquettes avec le nom / definitions /exemples mélangés et laisser les gens remettre dans l'ordre

- **système d'exploitation** : ensemble de logiciels qui gèrent les ressources de l'ordinateur.

Par exemple : Windows 8, MacOS, Ubuntu, Fedora pour les ordinateurs ; Android, iOS, GrapheneOS pour les smartphones.

- **internet** : c'est le réseau informatique mondial public.

- **navigateur web** : logiciel qui permet d'aller sur des sites internet et des les afficher.

Par exemple : Microsost Edge, Google Chrome, Mozilla Firefox, Safari, etc.

- **moteurs de recherche** : site internet offrant un service de recherche de contenu à travers Internet.

Par exemple : Google, Bing, Startpage, Qwant, DuckDuckGo, Ecosia, etc.

/!\ Sur mobile, presque tous les moteurs de recherche possèdent leur propre application. Ils sont alors à la fois navigateur internet et moteur de recherche.

- **les GAFAM** : acronyme désignant les géants du Web Google, Apple, Facebook, Amazon et Microsoft. Maintenant, le groupe qui a crée Facebook s'appelle Meta. Meta possède Facebook, Instagram et Whatsapp.

Quand on allume un ordinateur, il lance le système d'exploitation qui est installé. Dans ce système d'exploitation, on a accès à plein de logiciels. Parmi ces logiciels, on a un ou plusieurs navigateurs web qui nous permet de naviguer sur internet mais aussi des logiciels de messagerie, pour explorer les fichiers de l'ordinateur, pour faire de la mise en forme de documents, etc. Grâce à notre navigateur, on peut consulter un site internet si on connaît son adresse mais on peut aussi aller d'abord sur un moteur de recherche pour trouver ce site internet.

Exemple concret : j'allume mon ordinateur. Ubuntu se lance. J'ouvre Firefox. Je tape extinctionrebellion.fr et je peux consulter le site d'XR. Si j'ai oublié l'adresse (qu'on appelle URL), je peux aller sur Startpage et taper les mots-clés "Extinction Rébellion" et dans la liste des résultats je peux cliquer sur le site d'XR et je retomberai sur extinctionrebellion.fr.

Tout ça fonctionne également sur un smartphone car c'est comme un petit ordinateur.

Tous les outils que nous utilisons ont accès à des données sur nous. Se pose donc la question de la protection de la vie privée.

Avant tout, il faut définir certaines **notions liées à notre vie privée** :

- **la vie privée :** d'après le dictionnaire juridique Dalloz, "la vie privée est la sphère d'intimité de la personne. Elle se définit par opposition à la vie publique. Cette sphère a vocation à rester à l'abri des regards d'autrui. Le droit au respect de la vie privée est protégé au titre des droits de la personnalité." Préserver sa vie privée ne signifie pas que l'on a des secrets à cacher. Par exemple, nous savons ce qui se passe dans les toilettes mais nous fermons quand même la porte. Nous pouvons mettre des rideaux à nos fenêtres sans avoir à cacher une activité illégale ou mauvaises.
- **la confidentialité** : La définition de la confidentialité de l'Organisation Internationale de Normalisation (ISO) est « le fait de s'assurer que l'information est seulement accessible à ceux dont l'accès est autorisé. »

Par exemple : lorsqu'on décide d'envoyer un message à une personne spécifique sur Facebook ou Instagram plutôt que de publier un message public sur notre profil, c'est que l'on cherche de la confidentialité. Si quelqu'un peut intercepter la conversation, la confidentialité est menacée.

- **la sécurité** : assurance que le service ou la personne avec qui on interagit est authentique et que les données que l'on échange avec ne sont pas accessibles ou modifiables par une personne tierce.

Par exemple : lorsqu'on clique sur un lien dans un mail, il peut nous diriger vers un site qui n'est pas celui qu'on pense donc nos données peuvent être accessibles à une personne malveillante.

- **l'anonymat** : capacité d'agir sans identifiant permanent.

Par exemple : lorsqu'on s'inscrit à un service sous notre prénom et notre nom, notre compte est associé à notre identifiant permanent, nous ne sommes pas anonymes.

- **le pseudonymat** : capacité d'agir avec un identifiant permanent mais sans qu'il soit relié à votre identité réelle.

Par exemple : si vous vous présentez sous un pseudo lors de votre première réunion à XR et qu'on vous appelle comme ça par la suite, vous avez bien un identifiant permanent mais il n'est pas relié à votre identité réelle.

III.2. Modèle de menace - ATELIER

> **Point d'info (pas utile de le dire sauf questions)**
>
> Première partie. À la fin de la formation, une fois les outils présentés, on peut demander aux gens ce qu'ils comptent utiliser pour répondre à ce modèle de menace. Cela permattra aussi de juger le niveau de comphrension et d'avoir des questions plus pratiques.

On a très envie de commencer directement à mettre les mains dans le cambouis, mais avant ça il faut se poser quelques questions.

Un modèle de menace consiste simplement à ce demander qu'est ce qui pourrait arriver, qui pourrait le faire / comment cela pourrait se produire. Cela permet de se poser les bonnes questions pour savoir comment se protéger.

On peut se poser quelques questions pour commencer à réfléchir à notre modèle de menace. Selon votre modèle, certains outils présentés ici seront plus ou moins pertinents pour vous.

=> QUOI ? Que souhaitez-vous protéger ?

Exemples : contenu des conversations avec ses proches ou des échanges professionnels ; des fichiers (docs, photos, vidéos) stockés sur votre ordinateur, votre smartphone ou sur un cloud ; vos contacts ;

votre localisation actuelle et vos déplacements quotidiens ; des informations bancaires ou administratives ; etc.

-> Parmi les éléments à protéger, on en choisit un pour lequel on répondra aux autres questions.

=> DE QUI ? Qui peut mettre en danger cet élément ?

Exemples : un·e ex qui veut se venger, un·e patron·ne qui veut connaître à l'avance votre stratégie de négociation syndicale ; une entreprise concurrente ; un·e pirate qui veut récupérer vos données pour se faire de l'argent avec ; une institution qui vous surveille ; etc.

=> COMMENT ? Comment cet élément peut être menacé ?

Exemples : action physique sur un appareil (récupérer un fichier sur votre ordinateur à l'aide d'une clé USB) ; espionner votre navigation web sur le Wi-Fi public que vous êtes en train d'utiliser ; se faire passer pour une conseiller bancaire pour vous inciter à faire un virement ; infecter un de vos appareils ; mettre des traceurs dans une application de smartphone ; exploiter une faille de sécurité dans un logiciel que vous n'avez pas mis à jour depuis longtemps ; etc.

=> Quelle est la probabilité pour que cela arrive ?

Pas la peine de mettre énormément d'efforts contre quelque chose de très peu probable.

Idée : on peut attribuer un pourcentage, un score de 0 à 10, ou bien une couleur (rouge / jaune / vert).

=> Quelles conséquences si cela arrive ? Qu'est-ce qu'on a à perdre si ça arrive ?

Exemples : perdre de l'argent ; impact sur la réputation ; licenciement ; condamnation ; etc.

=> QUE FAIRE ? Quel compromis mettre en place ? Jusqu'à quel point suis-je prêt à me donner du mal pour essayer de prévenir les conséquences potentielles ?

La sécurité est une affaire de compromis. La sécurité ne peut jamais être totale mais peut être plus ou moins élevée selon les moyens qu'on est prêt·e à mettre en place et les coûts qui vont avec.

Exemples : coût financier (abonnement, achat de matériel) ; coût en commodité/praticité ou en temps (logiciel compliqué, plusieurs étapes pour s'authentifier) ; quitter un réseau social numérique ; etc.

Idées : on peut quantifier l'effort sur une échelle de 0 à 10, attribuer une couleur ou bien juste décrire quel(s) coût(s) on est prêt·es à accepter.

Point d'info (pas utile de le dire sauf questions)

On peut utiliser une matrice de risque pour modéliser cela.

III.3. Le capitalisme de surveillance, comment ça marche ?

La menace qui concerne presque tout le monde : les entreprises qui récupèrent énormément de données sur énormément de gens et qui croisent toutes les informations pour en faire des profils.

Ne croyez pas que vous n'êtes "pas intéressants" pour eux. Une récente analyse a essayé de quantifier ce phénomène.

Proton a essayé d'estimer, en parcourant les enchères publicitaires, combien un utilisateur rapporte à Google. C'est bien sûr très variable selon les profils (un ado avec son smartphone rapporte moins qu'un cadre bien payé avec son ordinateur). Attention, ces valeurs sont pour un utilisateur américain. On sait que les prix varient par pays.

Ressources

https://proton.me/blog/what-is-your-data-worth-to-google

Ainsi,
- un utilisateur américain rapporte en moyenne 1605 dollars par an à Google en publicité.
- max : 17929 dollars (35-44 ans, état du Montana, PC, haut niveau de vie)
- min : 31 dollars (14-24 ans, état de l'Arkansas, Android, père, faible niveau de vie)

Pour avoir des chiffres pour la France, on peut en première approximation diviser par 2 (le CPM d'un français est environ 2 fois moins élevé qu'un américain)

III.3.a. Collecter des données:
Des données (et surtout des metadonnées) sont constamment collectées de toutes part (réseaux sociaux, navigateurs, télémétrie de l'os, télémétrie des apps mobiles / bureau, rdv chez le médecin, fournisseur d'accès internet, abonnement d'élec, etc.).

Vous installez des applications ou vous créez un compte sur des sites internet, vous acceptez les conditions générales d'utilisation qui impliquent de livrer vos données. Le RGPD (Règlement général sur la protection des données) encadre légalement l'utilisation et le stockage de ces données. Vous consultez un site, on vous demande si vous acceptez les cookies, vous cliquez sur Accepter pour être tranquille : vous consentez à livrer vos données. Les données d'une application peuvent être accessibles à l'éditeur de l'application mais aussi à toutes les briques externes de l'application qui facilitent son développement ou son utilisation (programme qui gère la publicité, programme qui enregistre les stats d'utilisation, etc. : SDK).

III.3.b. Traiter les données :
Vos données d'utilisation d'une application précise un jour précis n'a pas de valeur. Mais croisées avec les données issues de toutes vos applications tous les jours ainsi qu'avec des millions d'autres utilisateur·ices, c'est une richesse précieuse !

Exemple : si vous avec un compte chez A avec votre numéro et votre mail, et un compte chez B avec votre numéro et votre nom prénom, le databroker va fusionner les 2 bases de données pour en avoir une seule avec votre numéro, mail et nom prénom. Après ils font pareil avec 1000 fois plus de données, même celles qui semblent les plus anodines du monde, comme : vous aimez le chocolat, vous scrollez 30 ms de plus sur le contenu qui présente des voitures rouges, vous achetez un shampooing spécifique, vos heures de lever et de coucher etc.

Les données sont achetées sur des marchés. Fusionnées depuis différentes sources par des courtiers en données (data brokers), elles deviennent des mines d'informations. Ces énormes quantités d'informations permettent d'établir des corrélations.

Exemples :

- « les gens qui aiment le chocolat ont 27,983 % plus de chances d'avoir un accident de voiture dans les x prochaines années. »).
- les personnes qui parlent par messages tard dans la nuit ont 12% de chance de voter violet plutôt que jaune ou orange.
- les personnes qui aiment les fraises ET qui ont installé des panneaux solaires dans les x dernières années ont x% de chance de tomber amoureux·se l'année qui suit.

Ça paraît absurde mais ils ont accès à tellement de données que les corrélations peuvent devenir des lois.

Ressources

- Rien à cacher ? Vous devriez… — Julien Osman (youtube) : https://youtu.be/MVj_5-tE9Q8
- Comment protéger sa vie privée sur son smartphone : https://youtu.be/yFDaty4b0fo

III.3.c. Exploiter les données :

Après tout ça, des entreprises peuvent disposer d'une énorme base de données sur vos goûts, préférences, comportements, habitudes, etc. et les associer avec d'autres comportements et goûts, etc. De nombreuses entreprises peuvent être intéressées par ces informations :

- n'importe quelle entreprise vendant un produit pour vous proposer des publicités ciblées ;
- des assureurs pour vous faire payer plus cher (ex. : si vous aimez le chocolat… ;-)) ;
- une complémentaire santé peuvent faire évoluer ses tarifs en fonction de vos chances d'avoir un cancer ;
- des partis politiques peuvent concentrer leurs efforts de campagne sur votre profil si vous faites partie de son électorat potentiel ;
- si un État supprime le droit à l'avortement, il aimerait probablement avoir une liste des personnes enceintes ET votant pour le parti Violet qui soutient le droit à l'avortement.

Remarque : ce qui est légal aujourd'hui peut être interdit dans 6 mois ou 1 an et Internet n'oublie jamais…

Exemple : le scandale Cambridge analytica

- En 2015, The Guradian a révélé qu'un politique américain Ted Cruz a utilisé les données de Cambridge Analytica, pour influencer des électeurs-clé (lesquels ignoraient, comme tous ceux qui ont fini par être spoliés de leurs données personnelles, que des sociétés exploitaient ces informations).
- En 2016, le comité de campagne de Donald Trump semble avoir modifié les intentions de vote (ou provoqué l'abstention) d'un nombre suffisamment important d'électeurs-clé pour conquérir le pouvoir. En analysant les personnalités des profils collectés au travers de leurs interactions sur la plateforme, l'équipe de Cambridge Analytica a pu discerner les partisans de Trump ainsi que les électeurs indécis[1].

Ressources

- Google, l'espion le plus con du monde : https://grisebouille.net/google-lespion-le-plus-con-du-monde
- La trouvaille glaçante d'un journaliste sur nos téléphones : https://youtu.be/UZjPHnN482M

III.4. ATELIER – DATA BROKERS

On forme des groupes de 2-3 personnes. Chaque groupe a un tableau de données. L'objectif est d'établir un profil le plus complet possible de Bernard. Ça va se faire en 2 étapes :

Étape 1 : chaque groupe extrait le plus d'infos possible sur Bernard grâce à son tableau.

Étape 2 : les groupes s'échangent leurs informations afin d'avoir un profil le plus complet possible.

[1] Des annonces personnalisées leur étaient alors envoyées : les partisans de Trump voyaient défiler sur leur fil d'actualité des images le représentant de manière triomphante, tandis que les indécis étaient exposés à des contenus mettant en scène ses fervents supporteurs, accompagnés de graphiques négatifs (+ fausses accusations de corruptions) à l'encontre de son opposante, Hillary Clinton.

III.4.a. Debrief

De la même manière, un journaliste a réussi à retrouver l'adresse d'agents du renseignement français et du GIGN.

Ressources

- A ce sujet, video d'Underscore_ https://www.youtube.com/watch?v=UZjPHnN482M

Les courtiers en données font la même chose avec des millions de personnes avec les données qu'on donne aux applications et sites web tous les jours. Voici les étapes:

III.4.b. Pour aller plus loin

L'**identifiant publicitaire unique** est un identifiant assigné par un système d'exploitation à un smartphone pour aider les publicitaires à tracer et à personnaliser les publicités. Il permet aussi aux plateformes et aux courtiers en données de relier l'activité des applications, la localisation et le comportement de l'utilisateur·ice pour cibler les publicités, générer des statistiques et croiser les données entre appareils. (https://privacy.ca.gov/2025/12/understanding-mobile-advertising-ids-and-drop/). L'utilisateur·ice peut remettre à zéro son identifiant manuellement.

« L'**OSINT** (*Open Source Intelligence*, ou Renseignement d'Origine Sources Ouvertes) est l'art de collecter, analyser et exploiter des informations accessibles au public. Ces données proviennent de sources ouvertes variées : sites web, réseaux sociaux, bases de données ouvertes, documents officiels, images satellites et bien plus encore. » (https://osintfr.com/osint/).

Point d'info (pas utile de le dire sauf questions)

ADINT (*Advertsing Intelligence) :* « Au cœur du système publicitaire numérique, un marché prospère se nourrit de nos données personnelles, alimentant un nouveau type de renseignement : l'ADINT (**Advertising Intelligence**), le renseignement par la publicité en ligne. Loin des regards, des entreprises exploitent les failles de ce système pour transformer les publicités en armes de surveillance. En se faisant passer pour de SIMples annonceurs, elles siphonnent les informations collectées par les applications mobiles pour établir des profils détaillés d'utilisateurs, suivre leurs déplacements (en temps quasi réel avec une approximation de 8 mètres) et même injecter des logiciels malveillants à distance. » (https://www.portail-ie.fr/univers/2025/adint-advertising-intelligence/)

Exemple de Monsieur Bernard (https://www.portail-ie.fr/univers/2025/adint-advertising-intelligence/) :

« Grâce à une investigation préliminaire en OSINT, nous savons qu'il réside aux Batignolles à Paris, qu'il travaille au siège de l'entreprise RandomCompany dans le 12e arrondissement, et qu'il rend régulièrement visite à sa famille à Rennes. Une campagne publicitaire ciblant ces trois lieux sur quelques semaines identifiera un utilisateur commun aux trois zones. La probabilité qu'un autre individu corresponde est infime : derrière ce MAID [identifiant publicitaire unique] pourtant anonyme se cache bien M. Bernard.

Une fois ce MAID collecté, l'opérateur d'ADINT se glisse à nouveau dans le système publicitaire en se faisant passer pour un SIMple annonceur. Il utilise les plateformes d'enchères en temps réel pour diffuser des publicités ciblées aux personnes qu'il souhaite surveiller. L'affichage ou le clic sur une publicité déclenche un mécanisme d'exfiltration de données complètement légal. Sans

qu'il le sache, le smartphone de M. Bernard transmet des informations d'apparence anodines à l'attaquant, via la plateforme publicitaire, qui sont ensuite analysées et agrégées pour créer son profil numérique complet : habitudes de navigation, applications utilisées, centres d'intérêt, déplacements… »

PAUSE

IV. Outils pratiques : se protéger

IV.1. Navigation web

IV.1.a. Fingerprinting

Le principal "risque" de la navigation.

Fingerprinting = ensemble de techniques de suivi en ligne qui permettent d'identifier de manière unique un appareil ou un utilisateur (User agent, adresse IP, cookies, cache, canvas, intégrations google/facebook sur les sites, javascript, extensions de navigateur, etc, résolution d'écran.).

C'est en lien avec la notion d'attribut unique dont on a parlé précédemment.

Du point de vue de l'entité qui veut vous identifier :

- reçoit une quantité de connexions ;
- le jeu c'est de trouver les différences entre ces connexions pour identifier lesquelles viennent du même appareil.

Ressources

- un VPN ne vous a JAMAIS protégé. (youtube) : youtu.be/Iz6QR3FAfnA
- Fingerprinting : comment on vous reconnaît même avec un VPN (youtube) : youtu.be/0XqtcAokt2U
- amiunique.org
- coveryourtracks.eff.org
- browserleaks.com

IV.1.b. Navigateurs web

Pas vraiment de solution ultime :(

- Soit on opte pour un navigateur plus respectueux de la vie privée + options de confidentialité stricte + extensions +bloqueur de javascript, etc. pour que le navigateur soit en mesure de collecter le moins de data possible, mais ça rend notre empreinte numérique plus unique (car la majorité des gens ne le font pas donc vous sortez du lot).
- Soit on choisit d'avoir une empreinte la moins unique possible, se fondre dans la masse mais le tracking est présent (et très présent).

Options de confidentialité :

- conteneurs + profils (depuis 157, encore plus efficace, moins de chance d'oublier) Firefox : ça isole les sites entre eux. Par exemple, vous pouvez dédié un conteneur à Facebook comme ça les

traceurs utilisés par Facebook ne voient pas les autres sites où vous allez. C'est aussi utile si vous avez plusieurs comptes sur un même site.

- supprimez les données de navigation à la fermeture (historique, cookies, suggestions de recherche, etc.) mais ça peut vous déconnectez de vos comptes selon ce que vous cochez.

Suggestions / À faire

- Firefox sur ordinateur avec certains paramètres de confidentialité ⟶ https://www.privacyguides.org/fr/desktop-browsers/
- Safari (uniquement pour iPhone) avec certains paramètres ⟶ https://www.privacyguides.org/fr/mobile-browsers/
- Ajouter des extensions comme ublock Origin (juste le nécessaire sinon ça augmente la surface d'attaque) : https://www.privacyguides.org/fr/browser-extensions/

Ressources

- The MOST private browser (youtube) : https://youtu.be/G09oVgDurTI
- https://privacytests.org
- https://eylenburg.github.io/browser_comparison.htm
- https://addons.mozilla.org/fr/firefox/addon/multi-account-containers/

(à ne pas confondre avec l'addon dédié à FB)

Point d'info (pas utile de le dire sauf questions)

- Pourquoi Firefox et pas chrome ou dérivés (Vivaldi, Bing, Brave) : ne permettent pas un blocage efficace des trackers et publicité.
- Pourquoi pas Brave : malgré leur marketing agressif sur la vie privée, ils ont tenté à leur début d'injecter eux-meme des publicité dites "privacy friendly" dans les pages. En 2020, ils injectaient des éléments dans les liens pour les utilisateurs de cryptomonnaie. De plus, le fondateur est anti LGBT. Enfin, en 2023, ils voulaient vendre les données de recherche des utilisateurs à des compagnies IA. Bref, ils ne sont pas dignes de confiance.

IV.1.c. Moteurs de recherche

Le principal problème : suivi des requêtes et partage avec des tiers.

=> **Solution : changer de moteur de recherche (pas Google ou Bing).**

Suggestions : DuckDuckGo ; Startpage.

IV.2. VPN

Définition de VPN (*Virtual Private Network) :* Interconnexion de réseaux locaux via une technique de tunnel sécurisé, généralement à travers Internet. On utilise notamment cette technologie en situation de télétravail ainsi que dans le cadre de l'informatique en nuage.

En gros : c'est un intermédiaire par lequel nos données passent avant d'aller vraiment sur Internet. Donc notre fournisseur d'accès ne voit pas ce qu'on fait sur Internet mais il voit uniquement qu'on utilise un VPN. Cependant, le VPN voit tout ce que vous faites donc vous transférez la confiance vers le VPN.

Parfois, c'est juste un VPN professionnel qui permet de faire comme si vous étiez dans votre bureau alors que vous êtes chez vous. Parfois, ça fait semblant que vous êtes aux États-Unis pour pouvoir regarder certaines séries sur Netflix. Parfois, ça passe par des serveurs appartenant à des entreprises qui vont chiffrer vos données.

Comment ça fonctionne : Voir diapo

Ça permet aussi de pas utiliser le DNS du FAI et donc de leur donner moins de data. C'est pas une solution magique parce :

- les connexions VPN sont parfois bloqués ;
- vous transférez tout votre trafic internet vers le serveur VPN (donc faut avoir confiance).

ATTENTION : les VPN ne garantissent pas l'anonymat ! Pour augmenter votre anonymat, il faut se tourner vers le navigateur Tor. On y reviendra en secu num 2.

Ressources

- The DARK side of VPNs (https://youtu.be/8MHBMdTBlok)
- NordVPN vous ment. (non sponsorisé) (https://youtu.be/ckZGQ5cLIfs)
- https://www.privacyguides.org/videos/2024/12/12/do-you-need-a-vpn
- https://www.privacyguides.org/fr/basics/vpn-overview
- https://ssd.eff.org/fr/module/choisir-le-rpv-qui-vous-convient
- https://thatoneprivacysite.xyz/#detailed-vpn-comparison
- https://vpn.techlore.tech

IV.3. Changer ses DNS

Point d'info (pas utile de le dire sauf questions)

Très simplement, il faut voir le DNS comme l'annuaire d'Internet : chaque fois que vous tapez une adresse (ex: google.com), votre appareil demande au serveur DNS de « traduire » ce nom en une adresse IP à contacter.

IV.3.a. Pourquoi en changer ?

1. Contourner la censure :

La liste de blocage DNS française a été instaurée en 2014 par Bernard Cazeneuve. Il s'agissait alors, officiellement, de permettre à la police de bloquer en urgence — c'est à dire **sans procédure judiciaire**, les faits les plus graves : apologie du terrorisme et images de pédopornographie.

Ce procédé a été progressivement étendu :
- à des cas bien plus bénins comme les sites de jeux
- à un nombre croissant de fournisseurs d'accès, dans des conditions également opaques. La police s'est initialement attaquée aux 4 plus grands FAI (Free, Orange, Bouygues, SFR) ; en 2023, de nombreux autres fournisseurs de plus petite taille sont également tenus de mettre en œuvre les blocages. Il est difficile de savoir qui et suivant quels critères ; on peut supposer qu'il s'agit d'initiatives de la police, au cas par cas.

Il est également à craindre que l'ampleur du système provoque une multiplication des "bavures" comme celle concernant Telegram en mai 2023 (t.me bloqué).

C’est le moyen le plus facile de bloquer un site pour le gouvernement, c’est aujourd’hui principalement utilisé pour bloquer les sites de streaming et de téléchargement, mais cela pourrait être étendu à l’avenir. C’est pour cette raison qu’il faut apprendre à en changer dès aujourd’hui !

2. Avoir une résolution de noms plus rapide (et donc des pages web qui se chargent un peu plus vite) : Parfois, certains serveurs DNS de fournisseurs d'accès sont lents. Il n'est pas rare que les fournisseurs DNS alternatifs soient plus rapide.
3. Être un peu plus en sécurité (certains serveurs DNS bloquent les domaines malveillants).
4. Effectuer un filtrage (certains serveurs DNS sont capable de filtrer la publicité, le tracking, les sites adultes…)
5. Peut être utilisé pour effectuer du filtrage sur des appareils où vous ne pouvez pas installer de logiciels de filtrage (mais juste configurer les serveurs DNS).

Bonus : Utiliser un DNS chiffré

Pour

- Masquer vos requêtes DNS (si vous utilisez le chiffrement DNS (DOH ou DOT)).
- Empêcher le fournisseur d'accès (ou point d'accès Wifi) de manipuler les réponses DNS (si vous utilisez le chiffrement DNS (DOH ou DOT)).

DoH/T veut dire DNS over HTTPS/TLS. Ce protocole permet l’encapsulation de requetes et de réponses DNS dans un canal HTTPS menant au résolveur. Le but est double : empecher un tiers de lire les requetes DNS, et protéger les r´eponses DNS contre des modifications, faites par exemple à des fins de censure.

Cependant DoH ne fait que sécuriser le canal de communication contre la surveillance et la manipulation par un tiers. Il ne garantit pas que le partenaire à l’autre bout du canal est de confiance.

Ressources

- https://sebsauvage.net/wiki/doku.php?id=dns-alternatifs (le goat)
- https://www.privacyguides.org/fr/dns/
- https://www.bortzmeyer.org/doh-et-ses-adversaires.pdf pour des critiques / nuances sur DoH

IV.4. Emails (et comptes en ligne en général)

Par défaut, l’email transite en clair sur le réseau : garder en tête que c’est un mode de communication non sécurisé. Dans l’idéal, on ne devrait jamais communiquer des informations importantes par email.

On a tous 10 000 comptes partout, souvent avec la même adresse email (et probablement le même mot de passe) : c’est autant de comptes qui contiennent des données et des metadonnées sur nous, et qui finissent inexorablement dans les mains des databrokers. Ici, le même email utilisé partout joue le rôle d’attribut unique qui leur servira à rassembler toutes les données des sites sous le même profil.

Solutions :

Suggestions / À faire

- Utiliser un gestionnaire de mot de passe ce qui permet de créer un mot de passe robuste différent pour chaque compte dont on n'a pas besoin de se souvenir.

Suggestion : KeePassXC, Bitwarden (attention), Vaultwarden. Si flemme, utiliser directement le gestionnaire de mot de passe de Firefox.

- Utiliser une adresse mail différente pour chaque compte : il n'est pas nécessaire de se créer une adresse mail à chaque fois, heureusement ! Il est possible d'utiliser les alias : des dérivés d'une adresse mail principale qui sert de « vitrine ». De plus, ses alias permettent de ne pas révéler votre adresse mail principale à n'importe quelle entreprise ou personne.

Exemple : votre adresse principale est dominique.dupont@gmail.com. Vous pouvez générer un alias dominique.dupont+achats@gmail.com pour votre compte Leboncoin. Il ne faut pas confondre cette possibilité avec la création d'un compte gmail dédié domi.achats@gmail.com qui demandera très certainement un numéro de téléphone ! Ainsi, si Leboncoin est victime d'une fuite de données, les personnes récupérant les données n'auront cette adresse utilisée une seule fois. De plus, personne n'a votre adresse principale (ni votre nom complet visible dans votre adresse principale). Cependant, il est assez facile de trouver la vraie adresse, même si dans la majorité des cas, cela ne sera pas fait.

Suggestions / À faire

Suggestion : Pour débuter, et si vous avez déjà un compte firefox, vous pouvez utiliser Firefox Relay qui propose la création de 5 alias gratuitement, de la forme fhishsxjkwg1@mozmail.com.

- Utiliser un pseudo par compte.
- Utiliser l'authentification à deux facteurs : confirmation par SMS ou par mail mais le mieux est d'utiliser une application spécifique (2FA TOTP) qui permet de générer un code unique temporaire.

Ressources

Ressources : The MOST private email service - Naomi Brockwell TV https://youtu.be/0_gGJtKX2Pw

IV.5. Les réseaux sociaux numériques

- Les réseaux sociaux numériques collectent énormément de données qui peuvent être croisées avec d'autres applications. De plus, certaines entreprises en possèdent plusieurs comme Meta (Instagram, Whatsapp, Messenger) ce qui simplifie le croisement.
- Volonté d'obtenir des identités complètes : CNI + Scan 3D du visage.

Point d'info (pas utile de le dire sauf questions)

- Lorsqu'on se promène dans la rue en ville, nous sommes à peu près anonymes. Seules les personnes vous connaissant sont capables de faire le lien entre votre visage et votre identité.

Cependant, si vous avez laissé des photos associées à votre nom complet, n'importe qui peut vous prendre en photo et retrouver votre identité grâce à une recherche d'images inversée.
- Les algorithmes d'intelligence artificielle sont de plus en plus performants pour créer des vidéos de toutes pièces à partir de photos. En laissant des photos à n'importe qui, quelqu'un peut créer un vidéo vous mettant en scène sans que ce soit vraiment arrivé.

Suggestions / À faire

- La plus radical : supprimer ses comptes des réseaux sociaux ⟶ quelle est votre utilisation ? Quelles conséquences si vous les quittez ? Quelles alternatives ? Par exemple, si vous n'utilisez Instagram que pour communiquer avec vos ami·e·s, envisagez d'utiliser Signal à la place.
- Au minimum : évitez de mettre une photo de vous en photo de profil ; évitez de partager des photos publiquement ; évitez d'associer votre identité complète avec votre photo.
- **Éventuellement, essayez des réseaux sociaux numériques plus respectueux de la vie privée comme Mastodon (https://www.privacyguides.org/fr/social-networks/?h=réseaux+sociaux.**

IV.6. Le réseau de téléphonie et internet mobile

Tout le tracking passe par la carte SIM, que ce soit pour les appels, SMS et les données mobiles, le fonctionnement est le même.

IV.6.a. Identifiants

Le téléphone se connecte à au moins une (souvent plusieurs) antennes relais qui lui permettent d'envoyer ou de recevoir des données (SMS, appels, 4G, 5G). Les antennes relais stockent deux identifiants : l'IMSI (identifiant de la carte SIM donc relié à notre abonnement et donc notre identité) et l'IMEI (identifiant du téléphone).

Point d'info (pas utile de le dire sauf questions)

La police ou les escrocs peuvent utiliser des IMSI catcher, des appareils qui imitent une antenne relais donc les mobiles s'y connectent et toutes les données peuvent être lues (SMS, appels). De plus, l'IMSI catcher peut simuler un appel ou SMS provenant d'un autre numéro. Exemple : « Vous avez reçu un colis ! Cliquez ici pour avoir les informations de suivi. »

Votre numéro de téléphone est un identifiant unique relié à votre identité : éviter de le donner si ce n'est pas indispensable ; réfléchissez bien si ça vaut le coup de le donner.

Vous pouvez aussi, si le site n'est pas connu mondialement, et s'il n'est pas sensible, utiliser des numéros de téléphone jetables. Tout le monde pourra voir les sms reçus, donc cela sert uniquement pour dépanner !

Ressources

Extrait de la Vidéo de 3:09 à 5 min de micode pas mal : https://www.youtube.com/watch?v=6Jv0EzXdQbk&t=189s

IV.6.b. Géolocalisation

Les outils fermés des GAFAM posent trois problèmes :

- **La surveillance continue :** La position est partagée en temps réel, même lorsque l'application est en arrière-plan, créant un historique exhaustif de vos trajets, de vos lieux de travail, de vos loisirs.
- **Le ciblage publicitaire géolocalisé :** Les applications des GAFAM orientent subtilement vos choix économiques en mettant en avant les commerces qui paient pour être visibles, faussant ainsi votre perception de l'espace public. Maps est avant tout un produit publicitaire pour Google, à destination des commerces.
- **La dépendance réseau :** Ces applications fonctionnent principalement "dans le cloud". Sans connexion internet (zone blanche, étranger), leurs fonctionnalités sont fortement dégradées ou totalement indisponibles.

Point d'info (pas utile de le dire sauf questions)

La solution réside dans l'utilisation d'**OpenStreetMap (OSM)**. Souvent décrit comme le *« Wikipédia de la carte »*, OSM est un projet mondial de cartographie collaborative, libre et gratuite.

- **Bien commun :** La carte appartient à ses utilisateurs et à une fondation à but non lucratif, pas à une multinationale. Les données sont donc objectives (dans la mesure du possible ^^) et pas biaisées par de la publicité
- **Respect de la vie privée :** Les données géographiques sont transparentes et le projet n'a aucun modèle économique basé sur la publicité ou le ciblage.
- **Précision incroyable :** Dans de nombreux endroits, les sentiers de randonnée, les pistes cyclables et les détails urbains (**points d'eau**, bancs, types de commerces) sont plus précis sur OSM que sur les cartes propriétaires. Très difficile de trouver des points d'eau sur GMaps par exemple.

IV.6.b.i. Les applications recommandées

OpenStreetMap constitue la base de données brute de la carte. Pour l'utiliser sur un smartphone, il est nécessaire d'installer une application "lectrice". Aujourd'hui, il y a 2 alternatives :

Application	Profil d'utilisateur	Points forts
CoMaps	Débutant / Grand public	Interface ultra-épurée, très rapide et sans fioritures. Idéale pour remplacer Google Maps au quotidien (voiture, vélo, piéton). Prise en main immédiate et intuitive.
OsmAnd	Utilisateur avancé / Randonneur	Extrêmement complète et paramétrable. Permet d'afficher les courbes de niveau, d'enregistrer des traces GPS (fichiers GPX), de superposer des couches de données et de configurer des profils de navigation complexes.

Le point commun de ces applications :
Elles sont toutes les deux **Open Source**, disponibles sur Android (via F-Droid et Google Play) et iOS,

et fonctionnent **sans aucun tracker publicitaire ni collecte de données**. **Cependant, 2 problèmes majeurs** :

1. La recherche : elle est très stricte, pour trouver un endroit, il faut taper exactement le nom de la rue ou du commerce avec la bonne orthographe, sinon cela ne fonctionne pas
2. Présence de commerce : Selon la zone, les commerces peuvent manquer ou ne pas être mis à jour. cela s'explique par le changement fréquent de commerce aux cours des mois.

Point d'info (pas utile de le dire sauf questions)

IV.6.b.ii. Téléchargement des cartes Hors-ligne

Au lieu de charger les tuiles de la carte au fur et à mesure de votre trajet via les données mobiles, vous téléchargez la carte de votre région ou de votre pays à l'avance, une fois, idéalement depuis une connexion Wi-Fi.

1. **Pas de traçage réseau :** Le tel se contente de recevoir passivement le signal des satellites GPS (ce qui est totalement anonyme). Aucune donnée de position ou de destination n'est renvoyée.
2. **Économie de batterie :** Le processeur du téléphone travaille moins car les données sont déjà stockées sur l'appareil, et les puces réseaux gourmandes en énergie restent au repos.
3. **Meilleure fiabilité :** La navigation et la recherche d'adresses fonctionnent parfaitement au milieu de la forêt, en haute montagne ou dans les pays étrangers sans surcoût de itinérance.

IV.6.c. Communication

Les SMS et les appels, ça transite en clair sur le réseau (en théorie, n'importe qui peut lire vos SMS et écouter vos appels en captant les ondes).

Suggestions / À faire

- Solution : utiliser des applications de communication chiffrées de bout en bout (E2EE).
- Suggestion : Signal.

MAIS ces applications peuvent malgré tout récupérer beaucoup de métadonnées !

C'est quoi les métadonnées ? C'est les informations qui accompagnent le contenu principal. Par exemple, tout ce qui est autour d'un mail en dehors du contenu (heure d'envoi, expéditeur, destinataire, taille de l'email, présence/absence de pièce jointe, taille de la pièce jointe, etc.).

Donc Whatsapp, Messenger, etc., c'est chiffré mais c'est pas pour autant que c'est safe.

Ressources

- https://ssd.eff.org/fr/module/communiquer-avec-autrui
- https://youtu.be/rTPBqWzjuyo The MOST PRIVATE Messaging Apps
- https://youtu.be/rtRQKQkvUfE Telegram Isn't As Private As You Think
- https://framablog.org/2021/02/04/utilisateurs-libres-ou-domestiques-whatsapp-et-les-autres Utilisateurs libres ou domestiqués ? WhatsApp et les autres

IV.7. Protéger ses appareils

IV.7.a. Télémétrie

La télémétrie c'est la collecte et la transmission automatisées des données à des fins de surveillance, d'analyse et d'optimisation des ressources. Les systèmes collectent des données pour "améliorer l'expérience utilisateur". En pratique, c'est un système souvent impossible à désactiver et qui nuit à la confidentialité et la vie privée. Les systèmes de télémétrie sont utilisés dans les OS grand public (windows, macos, ios, android, etc), mais aussi dans les programmes ou les applications mobiles.

Dans un premier temps, il n'est pas utile de changer d'OS. On pourra en parler lors de la deuxième partie de la formation.

Suggestions / À faire

- Sur smartphone, Installer F-Droid et nottament la suite d'apps Fossify https://search.f-droid.org/?q=Fossify&lang=fr

- vérifier les trackers dans les apps grâce à Exodus privacy (génère des rapports de confidentitalité sur les applications) et Aurora store (une couche du Play Store).

IV.7.b. Open Bar

Utiliser ces applications est un premier pas, mais si dans le même temps, d'autres applications sur votre téléphone continuent de collecter vos données de localisation, vous ne serez pas vraiment protégé. En effet, on trouve aujourd'hui plétore d'app sur le Play Store pour un meme besoin et il est tentant de prendre la première sur les résultats de recherche pour un besoin. Cependant, la plupart de ces applications sont des "mouchards" qui collectent vos données de localisation pour les revendre. Il est donc important de vérifier les permissions et les trackers de chaque application installée sur votre téléphone.

Par exemple, si j'installe un jeu et que l'accès au contact est demandé, vous pouvez être sur que ces infos sont dans la nature. De même, si l'application demande l'accès à la localisation (à part sur si une application de navigation), vous pouvez être sur que vos déplacements sont suivis.

IV.8. Alternatives pour sortir des GAFAM

Pour chaque activité de tous les jours, il existe des outils plus respectueux de la vie privée. Le but n'est pas de tout changer du jour au lendemain, mais de remplacer ses outils petit à petit, à son rythme.

On ne veut pas sortir d'un modèle centralisé pour aller vers un autre modèle centralisé. le but est juste de faire découvrir des alternatives. À vous de choisir la votre et celle qui vous convient le mieux. Les choix faits ici sont arbitraires et correspondent aux goûts des formateurices.

Activité	Utilisé	Alternatives possibles
Messagerie	WhatsApp, Messenger, iMessage	**Signal** (le plus simple), **Olvid** (français, sans numéro de tel)
E-mails	Gmail, Outlook	**Proton Mail** (chiffré, très simple), **Tutanota** (chiffré, allemand), **Infomaniak** (suisse)
Stockage / Cloud	Google Drive, iCloud, OneDrive	**Proton Drive**, **Nextcloud** (https://nextcloud.com/sign-up/), **Infomaniak kDrive**
Cartes / GPS	Google Maps, Apple Maps, Waze	**CoMap** ou **OsmAnd** (basés sur OpenStreetMap, fonctionnent hors-ligne sans pistage). Attention, prévenir pour les problèmes sur la recherche + commerces
Bureautique	Microsoft Office, Google Docs	**LibreOffice**, **OnlyOffice sur Nextcloud**, **Proton Drive**, **kDrive**

Table 1: Tableau comparatif des alternatives

IV.8.a. Gros fournisseurs "éthiques" tout en un pour un usage perso / non militant
Si vous voulez savoir quels sont les fournisseurs alternatifs, vous pouvez consulter la plaquette.

Point d'info (pas utile de le dire sauf questions)

IV.8.a.i. Proton
Proton propose le chiffrement e2e pour les documents et le stokage chiffré pour les mails. Permet de remplacer gmail, google docs et google sheet, google calendar et autres. Facile à prendre en main.

IV.8.a.ii. kDrive/kSuite
kSuite ne propose pas le chiffrement e2e mais est lui aussi très axès sur la protection de la vie privée. Propose les memes services que proton avec en plus kMeet, alternative à google meet/duo, etc.

IV.8.b. Framasoft
Framasoft est une association française de loi 1901 connue pour sa campagne **"Dégooglisons Internet"**. Elle met à disposition du grand public des alternatives libres aux services des géants du web. On peut citer Framapad (texte collaboratif), Framadate (sondages de dates), Framatalk (visio), Framafunny, etc. Par exemple, la mailing list d'XR Toulouse y est hébergée.

Ces services sont gratuits, sans publicité et sans inscription pour la plupart.

Framasoft n'a pas vocation à être un gros fournisseur "tout-en-un" où vous stockez toute votre vie numérique. C'est un tremplin, une aide ponctuelle. L'association ferme ou limite volontairement certains services (comme l'hébergement d'e-mails à vie) pour inciter les utilisateurs à ne pas recréer un "Google du libre" et à se tourner vers des hébergeurs plus locaux : les CHATONS.

Ressources

- https://www.infomaniak.com/en/ksuite/ksuite-pro/prices#comparision
- https://www.chatons.org/search/by-service

V. Fin aterlier modèle de menace

On demande aux gens quels outils ils peuvent utiliser pour répondre au modèle de menace qu'ils ont identifié. Ils peuvent faire un tableau avec les menaces et les outils pour y répondre.

VI. Résumé

On a vu beaucoup de choses, il ne faut pas devenir parano mais on peut déjà faire certaines choses pour avoir une meilleure "higiène numérique". Une tentative de résumé avec les choses à retenir classées par priorité.

VI.1. Sécuriser les comptes et les accès critiques

- Installer un gestionnaire de mots de passe
- Activer la double authentification (2FA).

VI.2. Nettoyer et blinder la navigation web quotidienne

- Utiliser **Mozilla Firefox** sur PC mais aussi et surtout sur MOBILE !
- **Installer uBlock Origin :** Elle supprime les publicités publicitaires, mais bloque surtout les scripts invisibles qui tracent vos habitudes de navigation. sur ordinateur et MOBILE !
- Configurez par défaut **DuckDuckGo** ou **Startpage**.

VI.3. Migrer vers un écosystème de navigation plus sain

- Débuter la transition sur Signal
- Utiliser une adresse ProtonMail/infomaniak/tutanota.
- Se passer de Google Drive et Google Doc avec les alternatives proposés ci-dessus.

VI.4. Chiffrer son réseau et masquer ses courriels

- Changer les DNS de vos équipements
- Utiliser des alias d'email

VII. Conclusion

Il n'est jamais trop tard pour commencer, les gens changent, les données périment.
VPN + navigateur-moteur de recherche privacy friendly + email privacy friendly + signal ⇒ vous avez fait la majorité du boulot (loi de Pareto : agir sur 20 % de causes permet de résoudre 80 % du problème). Pour éviter de se faire manipuler ⇒ comprendre comment ça fonctionne. Il vaut mieux changer petit à petit ses habitudes mais les garder plutôt que tout changer d'un coup, tenir une semaine et revenir à la case départ !

VIII. Annexes

VIII.1. Tableau des modifcations

Date	Opérations
01/09/2026	Création du document

26/10/2026	Ajout détails sur Cambrdige Analytica + Détails sur choix de Firefox + et pas Brave + Suppression de Cryptpad en alternative + Placement en PT Box de l'ADINT + Numérotation des pages